

GadgetExplorer

GadgetExplorer - nines-nine, GitHub.

- Published: date not stated
- Original: <https://github.com/nines-nine/GadgetExplorer>
- Preserved from: <https://github.com/nines-nine/GadgetExplorer> (preserved-copy) on 2026-08-04
- Repository commit: 819bb60bd9c158b80ea1b546673d67aca375f2a1
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Repository reading copy: selected documentation at the recorded commit. Source code is never checked out, built or run.

- Repository: <https://github.com/nines-nine/GadgetExplorer>
- Commit: 819bb60bd9c158b80ea1b546673d67aca375f2a1
- Documents preserved: 3

CONTRIBUTING.md

Blob 969747d76d61, 1042 bytes, at commit 819bb60bd9c1.

Contributing

Thanks for your interest in improving GadgetExplorer.

Workflow

1. Fork the repository.
2. Create a branch for your change.
3. Make your changes.
4. Build and run the tests:
 - `dotnet build .\GadgetExplorer.sln`
 - `dotnet test .\tests\GadgetExplorer.Tests\GadgetExplorer.Tests.csproj`

5. If you change the scanning engine, sink matching, profiles, or reporting behavior, run a before/after comparison on a larger real-world codebase and make sure expected findings are not unexpectedly lost.
6. Push your branch to your fork.
7. Open a pull request with a short summary of the change and any relevant test or scan notes.

Guidelines

- Keep changes small and focused.
- Follow the existing code style and project structure.
- Prefer the narrowest layer that owns the behavior you are changing.
- Add or update tests when behavior changes.
- If you change loading, indexing, dispatch, sink matching, profiles, or reporting, include targeted tests and then run the broader relevant test command before finishing.

LICENSE.txt

Blob f288702d2fa1 , 35149 bytes, at commit 819bb60bd9c1 .

GNU GENERAL PUBLIC LICENSE Version 3, 29 June 2007

Copyright (C) 2007 Free Software Foundation, Inc. <https://fsf.org/> Everyone is permitted to copy and distribute verbatim copies of this license document, but changing it is not allowed.

Preamble

The GNU General Public License is a free, copyleft license for software and other kinds of works.

The licenses for most software and other practical works are designed to take away your freedom to share and change the works. By contrast, the GNU General Public License is intended to guarantee your freedom to share and change all versions of a program--to make sure it remains free software for all its users. We, the Free Software Foundation, use the GNU General Public License for most of our software; it applies also to any other work released this way by its authors. You can apply it to your programs, too.

When we speak of free software, we are referring to freedom, not price. Our General Public Licenses are designed to make sure that you have the freedom to distribute copies of free software (and charge for them if you wish), that you receive source code or can get it if you want it, that you can change the software or use pieces of it in new free programs, and that you know you can do these things.

To protect your rights, we need to prevent others from denying you these rights or asking you to surrender the rights. Therefore, you have certain responsibilities if you distribute copies of the software, or if you modify it: responsibilities to respect the freedom of others.

For example, if you distribute copies of such a program, whether gratis or for a fee, you must pass on to the recipients the same freedoms that you received. You must make sure that they, too, receive or can get the source code. And you must show them these terms so they know their rights.

Developers that use the GNU GPL protect your rights with two steps: (1) assert copyright on the software, and (2) offer you this License giving you legal permission to copy, distribute and/or modify it.

For the developers' and authors' protection, the GPL clearly explains that there is no warranty for this free software. For both users' and authors' sake, the GPL requires that modified versions be marked as changed, so that their problems will not be attributed erroneously to authors of previous versions.

Some devices are designed to deny users access to install or run modified versions of the software inside them, although the manufacturer can do so. This is fundamentally incompatible with the aim of protecting users' freedom to change the software. The systematic pattern of such abuse occurs in the area of products for individuals to use, which is precisely where it is most unacceptable. Therefore, we have designed this version of the GPL to prohibit the practice for those products. If such problems arise substantially in other domains, we stand ready to extend this provision to those domains in future versions of the GPL, as needed to protect the freedom of users.

Finally, every program is threatened constantly by software patents. States should not allow patents to restrict development and use of software on general-purpose computers, but in those that do, we wish to avoid the special danger that patents applied to a free program could make it effectively proprietary. To prevent this, the GPL assures that patents cannot be used to render the program non-free.

The precise terms and conditions for copying, distribution and modification follow.

TERMS AND CONDITIONS

1. Definitions.

"This License" refers to version 3 of the GNU General Public License.

"Copyright" also means copyright-like laws that apply to other kinds of works, such as semiconductor masks.

"The Program" refers to any copyrightable work licensed under this License. Each licensee is addressed as "you". "Licensees" and "recipients" may be individuals or organizations.

To "modify" a work means to copy from or adapt all or part of the work in a fashion requiring copyright permission, other than the making of an exact copy. The resulting work is called a "modified version" of the earlier work or a work "based on" the earlier work.

A "covered work" means either the unmodified Program or a work based on the Program.

To "propagate" a work means to do anything with it that, without permission, would make you directly or secondarily liable for infringement under applicable copyright law, except executing it on a computer or modifying a private copy. Propagation includes copying,

distribution (with or without modification), making available to the public, and in some countries other activities as well.

To "convey" a work means any kind of propagation that enables other parties to make or receive copies. Mere interaction with a user through a computer network, with no transfer of a copy, is not conveying.

An interactive user interface displays "Appropriate Legal Notices" to the extent that it includes a convenient and prominently visible feature that (1) displays an appropriate copyright notice, and (2) tells the user that there is no warranty for the work (except to the extent that warranties are provided), that licensees may convey the work under this License, and how to view a copy of this License. If the interface presents a list of user commands or options, such as a menu, a prominent item in the list meets this criterion.

1. Source Code.

The "source code" for a work means the preferred form of the work for making modifications to it. "Object code" means any non-source form of a work.

A "Standard Interface" means an interface that either is an official standard defined by a recognized standards body, or, in the case of interfaces specified for a particular programming language, one that is widely used among developers working in that language.

The "System Libraries" of an executable work include anything, other than the work as a whole, that (a) is included in the normal form of packaging a Major Component, but which is not part of that Major Component, and (b) serves only to enable use of the work with that Major Component, or to implement a Standard Interface for which an implementation is available to the public in source code form. A "Major Component", in this context, means a major essential component (kernel, window system, and so on) of the specific operating system (if any) on which the executable work runs, or a compiler used to produce the work, or an object code interpreter used to run it.

The "Corresponding Source" for a work in object code form means all the source code needed to generate, install, and (for an executable work) run the object code and to modify the work, including scripts to control those activities. However, it does not include the work's System Libraries, or general-purpose tools or generally available free programs which are used unmodified in performing those activities but which are not part of the work. For example, Corresponding Source includes interface definition files associated with source files for the work, and the source code for shared libraries and dynamically linked subprograms that the work is specifically designed to require, such as by intimate data communication or control flow between those subprograms and other parts of the work.

The Corresponding Source need not include anything that users can regenerate automatically from other parts of the Corresponding Source.

The Corresponding Source for a work in source code form is that same work.

1. Basic Permissions.

All rights granted under this License are granted for the term of copyright on the Program, and are irrevocable provided the stated conditions are met. This License explicitly affirms

your unlimited permission to run the unmodified Program. The output from running a covered work is covered by this License only if the output, given its content, constitutes a covered work. This License acknowledges your rights of fair use or other equivalent, as provided by copyright law.

You may make, run and propagate covered works that you do not convey, without conditions so long as your license otherwise remains in force. You may convey covered works to others for the sole purpose of having them make modifications exclusively for you, or provide you with facilities for running those works, provided that you comply with the terms of this License in conveying all material for which you do not control copyright. Those thus making or running the covered works for you must do so exclusively on your behalf, under your direction and control, on terms that prohibit them from making any copies of your copyrighted material outside their relationship with you.

Conveying under any other circumstances is permitted solely under the conditions stated below. Sublicensing is not allowed; section 10 makes it unnecessary.

1. Protecting Users' Legal Rights From Anti-Circumvention Law.

No covered work shall be deemed part of an effective technological measure under any applicable law fulfilling obligations under article 11 of the WIPO copyright treaty adopted on 20 December 1996, or similar laws prohibiting or restricting circumvention of such measures.

When you convey a covered work, you waive any legal power to forbid circumvention of technological measures to the extent such circumvention is effected by exercising rights under this License with respect to the covered work, and you disclaim any intention to limit operation or modification of the work as a means of enforcing, against the work's users, your or third parties' legal rights to forbid circumvention of technological measures.

1. Conveying Verbatim Copies.

You may convey verbatim copies of the Program's source code as you receive it, in any medium, provided that you conspicuously and appropriately publish on each copy an appropriate copyright notice; keep intact all notices stating that this License and any non-permissive terms added in accord with section 7 apply to the code; keep intact all notices of the absence of any warranty; and give all recipients a copy of this License along with the Program.

You may charge any price or no price for each copy that you convey, and you may offer support or warranty protection for a fee.

1. Conveying Modified Source Versions.

You may convey a work based on the Program, or the modifications to produce it from the Program, in the form of source code under the terms of section 4, provided that you also meet all of these conditions:

a) The work must carry prominent notices stating that you modified it, and giving a relevant date.

b) The work must carry prominent notices stating that it is released under this License and any conditions added under section

1. This requirement modifies the requirement in section 4 to

"keep intact all notices".

c) You must license the entire work, as a whole, under this License to anyone who comes into possession of a copy. This License will therefore apply, along with any applicable section 7 additional terms, to the whole of the work, and all its parts, regardless of how they are packaged. This License gives no permission to license the work in any other way, but it does not invalidate such permission if you have separately received it.

d) If the work has interactive user interfaces, each must display Appropriate Legal Notices; however, if the Program has interactive interfaces that do not display Appropriate Legal Notices, your work need not make them do so.

A compilation of a covered work with other separate and independent works, which are not by their nature extensions of the covered work, and which are not combined with it such as to form a larger program, in or on a volume of a storage or distribution medium, is called an "aggregate" if the compilation and its resulting copyright are not used to limit the access or legal rights of the compilation's users beyond what the individual works permit. Inclusion of a covered work in an aggregate does not cause this License to apply to the other parts of the aggregate.

1. Conveying Non-Source Forms.

You may convey a covered work in object code form under the terms of sections 4 and 5, provided that you also convey the machine-readable Corresponding Source under the terms of this License, in one of these ways:

a) Convey the object code in, or embodied in, a physical product (including a physical distribution medium), accompanied by the Corresponding Source fixed on a durable physical medium customarily used for software interchange.

b) Convey the object code in, or embodied in, a physical product (including a physical distribution medium), accompanied by a written offer, valid for at least three years and valid for as long as you offer spare parts or customer support for that product model, to give anyone who possesses the object code either (1) a copy of the Corresponding Source for all the software in the product that is covered by this License, on a durable physical medium customarily used for software interchange, for a price no more than your reasonable cost of physically performing this conveying of source, or (2) access to copy the Corresponding Source from a network server at no charge.

c) Convey individual copies of the object code with a copy of the written offer to provide the Corresponding Source. This alternative is allowed only occasionally and noncommercially, and only if you received the object code with such an offer, in accord with subsection 6b.

d) Convey the object code by offering access from a designated place (gratis or for a charge), and offer equivalent access to the Corresponding Source in the same way through the same place at no further charge. You need not require recipients to copy the

Corresponding Source along with the object code. If the place to copy the object code is a network server, the Corresponding Source may be on a different server (operated by you or a third party) that supports equivalent copying facilities, provided you maintain clear directions next to the object code saying where to find the Corresponding Source. Regardless of what server hosts the Corresponding Source, you remain obligated to ensure that it is available for as long as needed to satisfy these requirements.

e) Convey the object code using peer-to-peer transmission, provided you inform other peers where the object code and Corresponding Source of the work are being offered to the general public at no charge under subsection 6d.

A separable portion of the object code, whose source code is excluded from the Corresponding Source as a System Library, need not be included in conveying the object code work.

A "User Product" is either (1) a "consumer product", which means any tangible personal property which is normally used for personal, family, or household purposes, or (2) anything designed or sold for incorporation into a dwelling. In determining whether a product is a consumer product, doubtful cases shall be resolved in favor of coverage. For a particular product received by a particular user, "normally used" refers to a typical or common use of that class of product, regardless of the status of the particular user or of the way in which the particular user actually uses, or expects or is expected to use, the product. A product is a consumer product regardless of whether the product has substantial commercial, industrial or non-consumer uses, unless such uses represent the only significant mode of use of the product.

"Installation Information" for a User Product means any methods, procedures, authorization keys, or other information required to install and execute modified versions of a covered work in that User Product from a modified version of its Corresponding Source. The information must suffice to ensure that the continued functioning of the modified object code is in no case prevented or interfered with solely because modification has been made.

If you convey an object code work under this section in, or with, or specifically for use in, a User Product, and the conveying occurs as part of a transaction in which the right of possession and use of the User Product is transferred to the recipient in perpetuity or for a fixed term (regardless of how the transaction is characterized), the Corresponding Source conveyed under this section must be accompanied by the Installation Information. But this requirement does not apply if neither you nor any third party retains the ability to install modified object code on the User Product (for example, the work has been installed in ROM).

The requirement to provide Installation Information does not include a requirement to continue to provide support service, warranty, or updates for a work that has been modified or installed by the recipient, or for the User Product in which it has been modified or installed. Access to a network may be denied when the modification itself materially and adversely affects the operation of the network or violates the rules and protocols for communication across the network.

Corresponding Source conveyed, and Installation Information provided, in accord with this section must be in a format that is publicly documented (and with an implementation available to the public in source code form), and must require no special password or key for unpacking, reading or copying.

1. Additional Terms.

"Additional permissions" are terms that supplement the terms of this License by making exceptions from one or more of its conditions. Additional permissions that are applicable to the entire Program shall be treated as though they were included in this License, to the extent that they are valid under applicable law. If additional permissions apply only to part of the Program, that part may be used separately under those permissions, but the entire Program remains governed by this License without regard to the additional permissions.

When you convey a copy of a covered work, you may at your option remove any additional permissions from that copy, or from any part of it. (Additional permissions may be written to require their own removal in certain cases when you modify the work.) You may place additional permissions on material, added by you to a covered work, for which you have or can give appropriate copyright permission.

Notwithstanding any other provision of this License, for material you add to a covered work, you may (if authorized by the copyright holders of that material) supplement the terms of this License with terms:

- a) Disclaiming warranty or limiting liability differently from the terms of sections 15 and 16 of this License; or
- b) Requiring preservation of specified reasonable legal notices or author attributions in that material or in the Appropriate Legal Notices displayed by works containing it; or
- c) Prohibiting misrepresentation of the origin of that material, or requiring that modified versions of such material be marked in reasonable ways as different from the original version; or
- d) Limiting the use for publicity purposes of names of licensors or authors of the material; or
- e) Declining to grant rights under trademark law for use of some trade names, trademarks, or service marks; or
- f) Requiring indemnification of licensors and authors of that material by anyone who conveys the material (or modified versions of it) with contractual assumptions of liability to the recipient, for any liability that these contractual assumptions directly impose on those licensors and authors.

All other non-permissive additional terms are considered "further restrictions" within the meaning of section 10. If the Program as you received it, or any part of it, contains a notice stating that it is governed by this License along with a term that is a further restriction, you may remove that term. If a license document contains a further restriction but permits relicensing or conveying under this License, you may add to a covered work material governed by the terms of that license document, provided that the further restriction does not survive such relicensing or conveying.

If you add terms to a covered work in accord with this section, you must place, in the relevant source files, a statement of the additional terms that apply to those files, or a notice indicating where to find the applicable terms.

Additional terms, permissive or non-permissive, may be stated in the form of a separately written license, or stated as exceptions; the above requirements apply either way.

1. Termination.

You may not propagate or modify a covered work except as expressly provided under this License. Any attempt otherwise to propagate or modify it is void, and will automatically terminate your rights under this License (including any patent licenses granted under the third paragraph of section 11).

However, if you cease all violation of this License, then your license from a particular copyright holder is reinstated (a) provisionally, unless and until the copyright holder explicitly and finally terminates your license, and (b) permanently, if the copyright holder fails to notify you of the violation by some reasonable means prior to 60 days after the cessation.

Moreover, your license from a particular copyright holder is reinstated permanently if the copyright holder notifies you of the violation by some reasonable means, this is the first time you have received notice of violation of this License (for any work) from that copyright holder, and you cure the violation prior to 30 days after your receipt of the notice.

Termination of your rights under this section does not terminate the licenses of parties who have received copies or rights from you under this License. If your rights have been terminated and not permanently reinstated, you do not qualify to receive new licenses for the same material under section 10.

1. Acceptance Not Required for Having Copies.

You are not required to accept this License in order to receive or run a copy of the Program. Ancillary propagation of a covered work occurring solely as a consequence of using peer-to-peer transmission to receive a copy likewise does not require acceptance. However, nothing other than this License grants you permission to propagate or modify any covered work. These actions infringe copyright if you do not accept this License. Therefore, by modifying or propagating a covered work, you indicate your acceptance of this License to do so.

1. Automatic Licensing of Downstream Recipients.

Each time you convey a covered work, the recipient automatically receives a license from the original licensors, to run, modify and propagate that work, subject to this License. You are not responsible for enforcing compliance by third parties with this License.

An "entity transaction" is a transaction transferring control of an organization, or substantially all assets of one, or subdividing an organization, or merging organizations. If propagation of a covered work results from an entity transaction, each party to that transaction who receives a copy of the work also receives whatever licenses to the work the party's predecessor in interest had or could give under the previous paragraph, plus a

right to possession of the Corresponding Source of the work from the predecessor in interest, if the predecessor has it or can get it with reasonable efforts.

You may not impose any further restrictions on the exercise of the rights granted or affirmed under this License. For example, you may not impose a license fee, royalty, or other charge for exercise of rights granted under this License, and you may not initiate litigation (including a cross-claim or counterclaim in a lawsuit) alleging that any patent claim is infringed by making, using, selling, offering for sale, or importing the Program or any portion of it.

1. Patents.

A "contributor" is a copyright holder who authorizes use under this License of the Program or a work on which the Program is based. The work thus licensed is called the contributor's "contributor version".

A contributor's "essential patent claims" are all patent claims owned or controlled by the contributor, whether already acquired or hereafter acquired, that would be infringed by some manner, permitted by this License, of making, using, or selling its contributor version, but do not include claims that would be infringed only as a consequence of further modification of the contributor version. For purposes of this definition, "control" includes the right to grant patent sublicenses in a manner consistent with the requirements of this License.

Each contributor grants you a non-exclusive, worldwide, royalty-free patent license under the contributor's essential patent claims, to make, use, sell, offer for sale, import and otherwise run, modify and propagate the contents of its contributor version.

In the following three paragraphs, a "patent license" is any express agreement or commitment, however denominated, not to enforce a patent (such as an express permission to practice a patent or covenant not to sue for patent infringement). To "grant" such a patent license to a party means to make such an agreement or commitment not to enforce a patent against the party.

If you convey a covered work, knowingly relying on a patent license, and the Corresponding Source of the work is not available for anyone to copy, free of charge and under the terms of this License, through a publicly available network server or other readily accessible means, then you must either (1) cause the Corresponding Source to be so available, or (2) arrange to deprive yourself of the benefit of the patent license for this particular work, or (3) arrange, in a manner consistent with the requirements of this License, to extend the patent license to downstream recipients. "Knowingly relying" means you have actual knowledge that, but for the patent license, your conveying the covered work in a country, or your recipient's use of the covered work in a country, would infringe one or more identifiable patents in that country that you have reason to believe are valid.

If, pursuant to or in connection with a single transaction or arrangement, you convey, or propagate by procuring conveyance of, a covered work, and grant a patent license to some of the parties receiving the covered work authorizing them to use, propagate, modify or convey a specific copy of the covered work, then the patent license you grant is automatically extended to all recipients of the covered work and works based on it.

A patent license is "discriminatory" if it does not include within the scope of its coverage, prohibits the exercise of, or is conditioned on the non-exercise of one or more of the rights that are specifically granted under this License. You may not convey a covered work if you are a party to an arrangement with a third party that is in the business of distributing software, under which you make payment to the third party based on the extent of your activity of conveying the work, and under which the third party grants, to any of the parties who would receive the covered work from you, a discriminatory patent license (a) in connection with copies of the covered work conveyed by you (or copies made from those copies), or (b) primarily for and in connection with specific products or compilations that contain the covered work, unless you entered into that arrangement, or that patent license was granted, prior to 28 March 2007.

Nothing in this License shall be construed as excluding or limiting any implied license or other defenses to infringement that may otherwise be available to you under applicable patent law.

1. No Surrender of Others' Freedom.

If conditions are imposed on you (whether by court order, agreement or otherwise) that contradict the conditions of this License, they do not excuse you from the conditions of this License. If you cannot convey a covered work so as to satisfy simultaneously your obligations under this License and any other pertinent obligations, then as a consequence you may not convey it at all. For example, if you agree to terms that obligate you to collect a royalty for further conveying from those to whom you convey the Program, the only way you could satisfy both those terms and this License would be to refrain entirely from conveying the Program.

1. Use with the GNU Affero General Public License.

Notwithstanding any other provision of this License, you have permission to link or combine any covered work with a work licensed under version 3 of the GNU Affero General Public License into a single combined work, and to convey the resulting work. The terms of this License will continue to apply to the part which is the covered work, but the special requirements of the GNU Affero General Public License, section 13, concerning interaction through a network will apply to the combination as such.

1. Revised Versions of this License.

The Free Software Foundation may publish revised and/or new versions of the GNU General Public License from time to time. Such new versions will be similar in spirit to the present version, but may differ in detail to address new problems or concerns.

Each version is given a distinguishing version number. If the Program specifies that a certain numbered version of the GNU General Public License "or any later version" applies to it, you have the option of following the terms and conditions either of that numbered version or of any later version published by the Free Software Foundation. If the Program does not specify a version number of the GNU General Public License, you may choose any version ever published by the Free Software Foundation.

If the Program specifies that a proxy can decide which future versions of the GNU General Public License can be used, that proxy's public statement of acceptance of a version permanently authorizes you to choose that version for the Program.

Later license versions may give you additional or different permissions. However, no additional obligations are imposed on any author or copyright holder as a result of your choosing to follow a later version.

1. Disclaimer of Warranty.

THERE IS NO WARRANTY FOR THE PROGRAM, TO THE EXTENT PERMITTED BY APPLICABLE LAW. EXCEPT WHEN OTHERWISE STATED IN WRITING THE COPYRIGHT HOLDERS AND/OR OTHER PARTIES PROVIDE THE PROGRAM "AS IS" WITHOUT WARRANTY OF ANY KIND, EITHER EXPRESSED OR IMPLIED, INCLUDING, BUT NOT LIMITED TO, THE IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE. THE ENTIRE RISK AS TO THE QUALITY AND PERFORMANCE OF THE PROGRAM IS WITH YOU. SHOULD THE PROGRAM PROVE DEFECTIVE, YOU ASSUME THE COST OF ALL NECESSARY SERVICING, REPAIR OR CORRECTION.

1. Limitation of Liability.

IN NO EVENT UNLESS REQUIRED BY APPLICABLE LAW OR AGREED TO IN WRITING WILL ANY COPYRIGHT HOLDER, OR ANY OTHER PARTY WHO MODIFIES AND/OR CONVEYS THE PROGRAM AS PERMITTED ABOVE, BE LIABLE TO YOU FOR DAMAGES, INCLUDING ANY GENERAL, SPECIAL, INCIDENTAL OR CONSEQUENTIAL DAMAGES ARISING OUT OF THE USE OR INABILITY TO USE THE PROGRAM (INCLUDING BUT NOT LIMITED TO LOSS OF DATA OR DATA BEING RENDERED INACCURATE OR LOSSES SUSTAINED BY YOU OR THIRD PARTIES OR A FAILURE OF THE PROGRAM TO OPERATE WITH ANY OTHER PROGRAMS), EVEN IF SUCH HOLDER OR OTHER PARTY HAS BEEN ADVISED OF THE POSSIBILITY OF SUCH DAMAGES.

1. Interpretation of Sections 15 and 16.

If the disclaimer of warranty and limitation of liability provided above cannot be given local legal effect according to their terms, reviewing courts shall apply local law that most closely approximates an absolute waiver of all civil liability in connection with the Program, unless a warranty or assumption of liability accompanies a copy of the Program in return for a fee.

END OF TERMS AND CONDITIONS

How to Apply These Terms to Your New Programs

If you develop a new program, and you want it to be of the greatest possible use to the public, the best way to achieve this is to make it free software which everyone can redistribute and change under these terms.

To do so, attach the following notices to the program. It is safest to attach them to the start of each source file to most effectively state the exclusion of warranty; and each file should have at least the "copyright" line and a pointer to where the full notice is found.

<one line to give the program's name and a brief idea of what it does.> Copyright (C)
<year> <name of author>

This program is free software: you can redistribute it and/or modify it under the terms of the GNU General Public License as published by the Free Software Foundation, either version 3 of the License, or (at your option) any later version.

This program is distributed in the hope that it will be useful, but WITHOUT ANY WARRANTY; without even the implied warranty of MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the GNU General Public License for more details.

You should have received a copy of the GNU General Public License along with this program. If not, see <https://www.gnu.org/licenses/>.

Also add information on how to contact you by electronic and paper mail.

If the program does terminal interaction, make it output a short notice like this when it starts in an interactive mode:

```
<program> Copyright (C) <year> <name of author> This program comes with  
ABSOLUTELY NO WARRANTY; for details type show w'. This is free software, and you are  
welcome to redistribute it under certain conditions; type show c' for details.
```

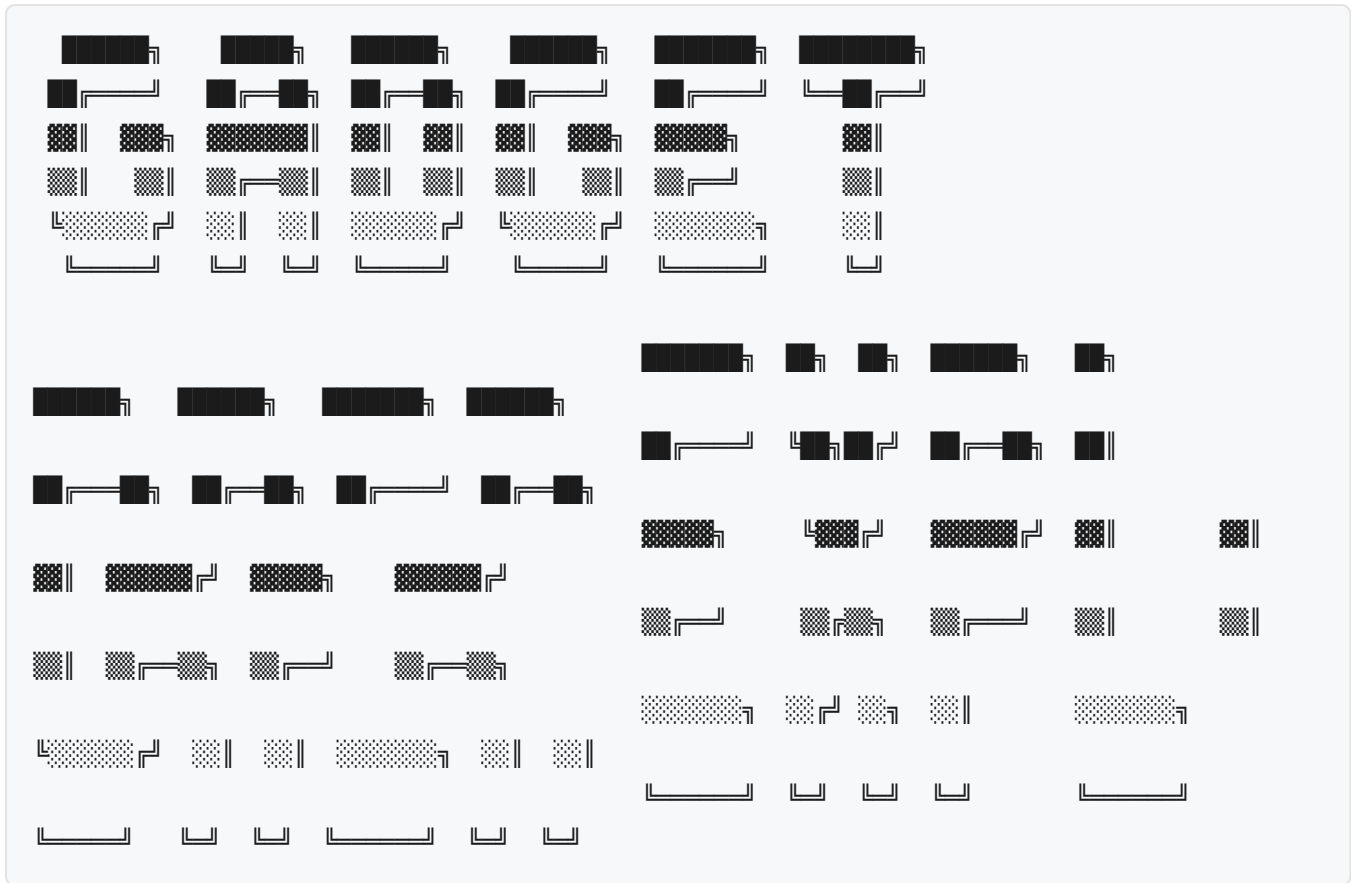
The hypothetical commands `show w'` and `show c'` should show the appropriate parts of the General Public License. Of course, your program's commands might be different; for a GUI interface, you would use an "about box".

You should also get your employer (if you work as a programmer) or school, if any, to sign a "copyright disclaimer" for the program, if necessary. For more information on this, and how to apply and follow the GNU GPL, see <https://www.gnu.org/licenses/>.

The GNU General Public License does not permit incorporating your program into proprietary programs. If your program is a subroutine library, you may consider it more useful to permit linking proprietary applications with the library. If this is what you want to do, use the GNU Lesser General Public License instead of this License. But first, please read <https://www.gnu.org/licenses/why-not-lgpl.html>.

README.md

Blob 3e2a1a04f4b9 , 20764 bytes, at commit 819bb60bd9c1 .



Deserialization Gadget Chain Discovery for .NET Applications

Overview

GadgetExplorer is a .NET command-line tool for finding potential deserialization gadget chains in managed applications. It scans one or more assemblies, builds a reachability graph with dispatch and callback heuristics, and reports when a deserialization entrypoint can reach a sink you care about.

The tool is aimed at people doing .NET deserialization research, gadget hunting, exploit development and vulnerability research of managed applications. It is especially useful when you already know which serializer behavior and sink families you care about and want a faster way to answer: "Could this deserialization entrypoint lead to a usable gadget chain into this sink?"

Out of the box, the shipped sink set contains hundreds of sinks, covering common categories such as:

- File writes and filesystem impact: `System.IO.File.WriteAllText`, `System.IO.File.WriteAllBytes`, `System.IO.FileStream.Write`, `System.IO.Compression.ZipFile.ExtractToDirectory`
- Command or script execution: `System.Diagnostics.Process.Start`, `System.Management.Automation.PowerShell.Invoke`

- SSRF and outbound network access: `System.Net.WebRequest.Create` , `System.Net.WebRequest.GetResponse` , `System.Net.Http.HttpClient.GetAsync` , `System.Net.Http.HttpClient.SendAsync` , `System.Net.WebClient.DownloadString`
- XXE-adjacent XML loading and transform paths: `System.Xml.XmlDocument.LoadXml`
- Reflection and dynamic invocation: `System.Reflection.MethodBase.Invoke` , `System.Reflection.MethodInfo.Invoke` , `System.Type.InvokeMember` , `System.Activator.CreateInstance`
- Chained deserialization: `System.Runtime.Serialization.Formatters.Binary.BinaryFormatter.Deserialize` , `System.Runtime.Serialization.Formatters.Soap.SoapFormatter.Deserialize` , `System.Runtime.Serialization.NetDataContractSerializer.Deserialize`
- Assembly loading and dynamic code loading: `System.Reflection.Assembly.Load` , `System.Reflection.Assembly.LoadFrom` , `System.Reflection.Assembly.UnsafeLoadFrom`

Installation

Download the latest release archive from this repository's GitHub Releases page, extract it, and keep the contents together.

The release folder is intentionally file-backed:

- `GadgetExplorer.exe` : the scanner executable
- `sinks\*.sinks.json` : the default shipped include-sink pack, grouped by broad vulnerability class
- `ignore-sinks\*.ignore-sinks.json` : the default shipped ignore-sink pack
- `serializer-profiles\*.profile.json` : the shipped built-in serializer profiles

Run the tool from that directory, or invoke `GadgetExplorer.exe` directly while keeping those sidecar folders beside it.

Build From Source

Restore dependencies:

```
dotnet restore
```

Build a release binary:

```
dotnet build .\GadgetExplorer.sln -c Release
```

The build output lands under `artifacts\bin\...`

Usage

Usage:

GadgetExplorer <assembly-or-directory> [options]

Input:

<assembly-or-directory>

Assembly file or directory tree to scan.

Directories are searched recursively **for** managed assemblies and runtimeconfig files.

Example: GadgetExplorer "C:\Target\App" -p JsonDotNet

Note: At least one assembly or directory is required.

Profile:

-p, --profile [BinaryFormatter | JsonDotNet | JsonDotNetGetters | MessagePackTypeless | PublicTwoStringConstructor | XmlSerializer]

Use a shipped serializer profile.

This controls which deserialization trigger policy and activation policies are modeled.

Required unless --profile-file is used.

Example: -p JsonDotNet

-pf, --profile-file <path>

Use a custom serializer profile JSON file.

This replaces built-in profile selection **for** the scan.

Required unless --profile is used.

Example: -pf .\Profiles\Custom.profile.json

Sink Configuration:

-is, --sinks <path>

Load a custom sink JSON file or a directory of *.sinks.json files.

This changes which methods count as reportable sinks.

Default: **use** the shipped `sinks` directory beside the executable.

Example: -is .\CustomSinks.json

-ig, --ignore-sinks <path>

Load a custom ignore-sink JSON file or a directory of *.ignore-sinks.json files.

This suppresses configured sink patterns and can reduce noise.

Default: **use** the shipped `ignore-sinks` directory beside the executable.

Example: -ig .\CustomIgnoreSinks.json

Scan Behavior:

-ie, --interface-expansion [off | strict | broad]

Control dynamic dispatch handling during graph construction.

off: only follow **interface** calls when concrete receiver identity is already known.

strict: allow strong receiver evidence, but stop when evidence runs out.

broad: opt into heuristic fallback across compatible implementations.

Default: strict.

Example: -ie broad

-s, --sort [shortest-path | per-sink-shortest-path | type-name]

Control finding order in the **final** report.

shortest-path: shortest paths first globally.

per-sink-shortest-path: group by sink, then shortest paths first within each sink.

type-name: stable type-centric ordering by root **class** identity.

Default: shortest-path.

Example: -s per-sink-shortest-path

-mpl, --max-path-length <n>

Limit the maximum graph path length **from** trigger to sink.

Lower values reduce noise and runtime but hide longer gadget chains.

Default: unbounded.

Example: -mpl 8

-arm, --assembly-resolution-mode [restricted | inference-no-fallback | inference-with-fallback]

Control how assembly resolution expands beyond the supplied input roots.

restricted: only resolve assemblies inside the supplied directory tree or beside supplied assembly files.

inference-no-fallback: infer the target runtime **from** runtimeconfig files, but stay inside the inputs **if** inference fails.

inference-with-fallback: infer the target runtime first, then fall back to the host runtime **if** inference fails.

Default: inference-no-fallback.

Output:

-o, --output <path>

Write the **final** report to a file.

Progress still goes to the console; only the report is redirected.

The output path does not choose the format; **use** --output-format **for** that.

Default: write the report to stdout.

Example: -o .\Scan.txt

-of, --output-format [text | json]

Control the **final** report serialization format.

text: the existing human-readable report.

json: a structured machine-friendly document with recon metadata and flat ordered findings.

Default: text.

Example: -of json

Structured JSON output is intended for downstream tooling. It keeps the same rendered finding order as the text report, but emits the scan heading and each finding as typed fields that are easier to filter, sort, and group.

Built-In Profiles

The shipped built-in profiles are:

- **JsonDotNet**: models the `Json.NET TypeNameHandling != None` scenario with constructor selection, public property setters, `JsonProperty / DataMember`-opted non-public setters, deserialization callback attributes including `OnError`, finalizers enabled, and public plus non-public root types when type resolution reaches them.
- **JsonDotNetGetters**: a narrower `Json.NET`-oriented profile for the same `TypeNameHandling != None` scenario. It disables constructor, setter, callback, and finalizer trigger surfaces and focuses on public property getters while keeping the same root-type visibility coverage as `JsonDotNet`.
- **BinaryFormatter**: models `BinaryFormatter`-style behavior with `[Serializable]` roots, uninitialized object creation, exact-signature `ISerializable` serialization constructors across constructor visibilities, deserialization callback attributes, `IDeserializationCallback`, `IObjectReference`, and finalizers.
- **MessagePackTypeless**: models unsafe `MessagePack-CSharp Typeless` deserialization through `MessagePackSerializer.Typeless / TypelessContractlessStandardResolver`, including annotated and unannotated contractless roots, constructor triggers with `SerializationConstructor` precedence and best-match selection, public plus non-public property setter triggers reachable through the allow-private path, `IMessagePackSerializationCallbackReceiver.OnAfterDeserialize()`, and finalizers. It intentionally does not add field-only trigger modeling or broader custom formatter execution.
- **XmlSerializer**: models publicly visible roots, parameterless-constructor activation, public property setters, `IXmlSerializable.ReadXml(XmlReader)`, finalizers enabled, conservative ordinary-member compatibility filtering for interface and `System.Type` member shapes, and no formatter-style callbacks.
- **PublicTwoStringConstructor**: a narrow research profile for objects reached through a publicly visible type with a public constructor taking exactly two `System.String` parameters, with finalizers enabled and setter/callback behavior disabled.

Sink Files

- `sinks\*.sinks.json` : define which methods count as sinks worth reporting.
- `ignore-sinks\*.ignore-sinks.json` : define sink patterns that should be ignored or treated as slice boundaries.

Both file types use a JSON document with a top-level `sinks` array. The `--sinks` and `--ignore-sinks` options accept either one JSON file or one directory. When a directory is supplied, GadgetExplorer reads only the top directory, loads matching files, sorts them by file name using ordinal comparison, and concatenates their `sinks` arrays deterministically. Include-sink files can be broad or signature-specific. The richer `parameters` form lets each parameter independently opt into constant-argument suppression:

```
{
  "sinks": [
    {
      "declaringType": "System.Xml.XmlDocument",
      "methodName": "Load",
      "parameters": [
        {
          "typeName": "System.String",
          "ignoreSinkIfConstant": true
        }
      ]
    }
  ]
}
```

`ignoreSinkIfConstant` applies to include-sink definitions only. It means "do not report this sink if GadgetExplorer concludes that the value passed to this parameter is constant at the call site." This is useful for reducing noise from APIs such as `XmlDocument.Load(string)` when the XML path is a hard-coded local configuration file. That determination is heuristic rather than perfect, so constant detection should be treated as a noise-reduction aid, not as proof that a path is safe.

Ignore-sink files do not use `ignoreSinkIfConstant`. They simply describe sink patterns that should be ignored or used as slice boundaries.

Examples

Scan a single assembly with the built-in Json.NET profile:

```
.\GadgetExplorer.exe .\App.dll -p JsonDotNet -o .\Scan-JsonDotNet.txt
```

Use the shipped sink directories by default:

```
.\GadgetExplorer.exe "C:\Target\App" -p JsonDotNet -o .\Scan-DefaultSinks.txt
```

Scan a directory tree with the built-in BinaryFormatter profile using a max path length of 12:

```
.\GadgetExplorer.exe "C:\Target\App" -p BinaryFormatter -mpl 12 -o .\Scan-BinaryFormatter.txt
```

Scan a directory tree with the built-in XmlSerializer profile:

```
.\GadgetExplorer.exe "C:\Target\App" -p XmlSerializer -o .\Scan-XmlSerializer.txt
```

Scan a directory tree with the built-in MessagePack Typeless profile and a max path length of 8:

```
.\GadgetExplorer.exe "C:\Target\App" -p MessagePackTypeless -mpl 8 -o .\Scan-MessagePackTypeless.txt
```

Use the built-in Json.NET profile with a custom sink file, a custom ignore-sink file, and type-name sorting:

```
.\GadgetExplorer.exe "C:\Target\App" -p JsonDotNet -is .\CustomIncludeSinks.json -ig .\CustomIgnoreSinks.json -s type-name -o .\Scan-CustomSinks-TypeName.txt
```

Use the built-in Json.NET profile with a custom sink directory:

```
.\GadgetExplorer.exe "C:\Target\App" -p JsonDotNet -is .\CustomSinks -o .\Scan-CustomSinkDirectory.txt
```

Write the structured JSON report to disk for downstream processing:

```
.\GadgetExplorer.exe "C:\Target\App" -p JsonDotNet -of json -o .\Scan-JsonDotNet.json
```

Infer the target runtime from runtimeconfig files, but stay inside the supplied inputs if inference fails:

```
.\GadgetExplorer.exe "C:\Target\App" -p JsonDotNet -arm inference-no-fallback -o .\Scan-InferenceNoFallback.txt
```

Infer the target runtime first, then allow host-runtime fallback if inference fails:

```
.\GadgetExplorer.exe "C:\Target\App" -p JsonDotNet -arm inference-with-fallback -o
.\Scan-InferenceWithFallback.txt
```

Use a built-in profile with explicit interface handling, sorting, and max path length:

```
.\GadgetExplorer.exe .\App.dll -p JsonDotNet -arm restricted -ie broad -s shortest-path -
mpl 8 -o .\Scan-Restricted-Broad.txt
```

Use a custom serializer profile file, a custom sink file, custom ignore sinks, sort by per-sink shortest path, and cap paths at 12:

```
.\GadgetExplorer.exe "C:\Target\App" -pf .\Profiles\Custom.profile.json -is
.\CustomIncludeSinks.json -ig .\CustomIgnoreSinks.json -s per-sink-shortest-path -mpl 12
-o .\Scan-Custom.txt
```

Sample Findings

Arbitrary Method Invocations

```
System.Windows.Data.ObjectDataProvider, PresentationFramework, Version=4.0.0.0,
Culture=neutral, PublicKeyToken=31bf3856ad364e35
  Assembly: C:\Example\AppA\PresentationFramework.dll (AssemblyVersion=4.0.0.0,
FileVersion=4.800.122.15205, Origin=input-root)
    System.Windows.Data.ObjectDataProvider::set_MethodName(System.String)
      -> [DirectCall] System.Windows.Data.DataSourceProvider::Refresh()
      -> [VirtualDispatch] System.Windows.Data.ObjectDataProvider::BeginQuery()
      -> [DirectCall] System.Windows.Data.ObjectDataProvider::QueryWorker(System.Object)
      -> [DirectCall]
    System.Windows.Data.ObjectDataProvider::InvokeMethodOnInstance(System.Exception&)
      -> [DirectCall] System.Type::InvokeMember(System.String,
System.Reflection.BindingFlags, System.Reflection.Binder, System.Object, System.Object[],
System.Globalization.CultureInfo)
```

Arbitrary Getters

```
System.Windows.Forms.BindingSource, System.Windows.Forms, Version=9.0.0.0,
Culture=neutral, PublicKeyToken=b77a5c561934e089
  Assembly: C:\Example\AppB\System.Windows.Forms.dll (AssemblyVersion=9.0.0.0,
FileVersion=9.0.1326.6403, Origin=input-root)
    System.Windows.Forms.BindingSource::set_DataMember(System.String)
      -> [DirectCall] System.Windows.Forms.BindingSource::ResetList()
      -> [DirectCall] System.Windows.Forms.ListBindingHelper::GetList(System.Object,
System.String)
      -> [VirtualDispatch]
System.ComponentModel.ReflectPropertyDescriptor::GetValue(System.Object)
  -> [DirectCall] System.Reflection.MethodBase::Invoke(System.Object,
System.Object[])
```

BinaryFormatter Bridges

```
System.Security.Principal.GenericIdentity, mscorlib, Version=4.0.0.0, Culture=neutral,
PublicKeyToken=b77a5c561934e089
  Assembly: C:\Example\AppC\Managed\mscorlib.dll (AssemblyVersion=4.0.0.0,
FileVersion=4.6.57.0, Origin=input-root)
  Declared On: System.Security.Claims.ClaimsIdentity
  Note: Inherited deserialization callback declared on
System.Security.Claims.ClaimsIdentity.

System.Security.Claims.ClaimsIdentity::OnDeserializedMethod(System.Runtime.Serialization.
StreamingContext)
  -> [DirectCall]
System.Security.Claims.ClaimsIdentity::DeserializeClaims(System.String)
  -> [DirectCall]
System.Runtime.Serialization.Formatters.Binary.BinaryFormatter::Deserialize(System.IO.Str
eam, System.Runtime.Remoting.Messaging.HeaderHandler, System.Boolean)
```

SSRF

```
System.Drawing.Bitmap, System.Drawing, Version=4.0.0.0, Culture=neutral,
PublicKeyToken=b03f5f7f11d50a3a
  Assembly: C:\Example\AppC\Managed\System.Drawing.dll (AssemblyVersion=4.0.0.0,
FileVersion=4.6.57.0, Origin=input-root)
  Declared On: System.Drawing.Image
  Note: Inherited finalizer declared on System.Drawing.Image.
    System.Drawing.Image::Finalize()
      -> [VirtualDispatch] System.Drawing.Image::Dispose(System.Boolean)
      -> [DirectCall] System.IO.Stream::Dispose()
      -> [VirtualDispatch] System.IO.Stream::Close()
      -> [VirtualDispatch]
System.Net.WebClient+WebClientWriteStream::Dispose(System.Boolean)
  -> [VirtualDispatch] System.Net.WebClient::GetWebResponse(System.Net.WebRequest)
  -> [VirtualDispatch] System.Net.HttpWebRequest::GetResponse()
```

Arbitrary Assembly Load

```
System.CodeDom.Compiler.CompilerResults, System.CodeDom, Version=9.0.0.0,
Culture=neutral, PublicKeyToken=cc7b13ffcd2ddd51
  Assembly: C:\Example\AppD\System.CodeDom.dll (AssemblyVersion=9.0.0.0,
FileVersion=9.0.325.11113, Origin=input-root)
    System.CodeDom.Compiler.CompilerResults::get_CompiledAssembly()
      -> [DirectCall] System.Reflection.Assembly::LoadFile(System.String)
```

Limitations

GadgetExplorer is not a general-purpose taint engine and it is not a push-button exploitability oracle. It is a researcher-assisted tool that surfaces candidate deserialization gadget chains for further manual analysis.

Current implementation limits include:

- It does not track object state through gadget chains. In practice, that means no general field/property taint propagation across object population steps.
- It does not perform full symbolic execution or path-sensitive branching analysis.
- It does not model arbitrary reflection semantics beyond the graph edges present in the loaded code.
- It does not model arbitrary event semantics. It handles the common observed subscription-and-raise pattern, not every possible event usage.
- Interface dispatch is modeled carefully, but still heuristically. Missing metadata, facade/reference mismatches, or incomplete receiver information can still produce under- or over-approximation.

- Restricted-mode results depend on what gets loaded. If you omit assemblies, the graph can miss paths. If you allow runtime inference and fallback, the graph can grow noisier.
- `--assembly-resolution-mode restricted` improves containment and repeatability, but it can also hide real paths that rely on runtime/framework assemblies outside the supplied tree.
- The default `inference-no-fallback` mode usually gives broader framework-aware coverage while still avoiding host-runtime fallback when inference fails.
- `--interface-expansion off` keeps only interface calls backed by concrete receiver identity, so subtype-constraint and exploratory fallback paths disappear.
- `--interface-expansion broad` enables exploratory fallback heuristics, which can surface additional paths but is intentionally noisier than `strict`.

License

GPLv3

Copyright

Copyright (C) 2026 Dane Evans

Archived from <https://github.com/nines-nine/GadgetExplorer>. Rendered offline from the local Markdown copy.